

Security and Custody

September 20, 2026

Version 1.0

Where the money sits, what can reach it, and what happens if we disappear

Asher Wilson, Founder

asher@maschine.dev

Abstract

Maschina does not hold user funds and cannot send them anywhere except back to their owner. This document explains the mechanisms behind that claim, the separation of powers that supports it, the assumptions the system is designed against, and the parts that are not built yet. Roughly forty percent of stolen funds in this industry come from key compromise rather than protocol defects, which is why custody rather than cleverness is the first subject of this paper.

1. The claim, and the reason to believe it

Maschina does not hold your money and cannot send it anywhere except back to you.

That is a property of the architecture rather than an undertaking. The rest of this document is the mechanism, because a security claim without a mechanism is a slogan.

2. Where the money actually is

Each machine has a wallet created for it at a regulated key management provider. The key is generated and held in hardware, and export is permanently denied, including to us.

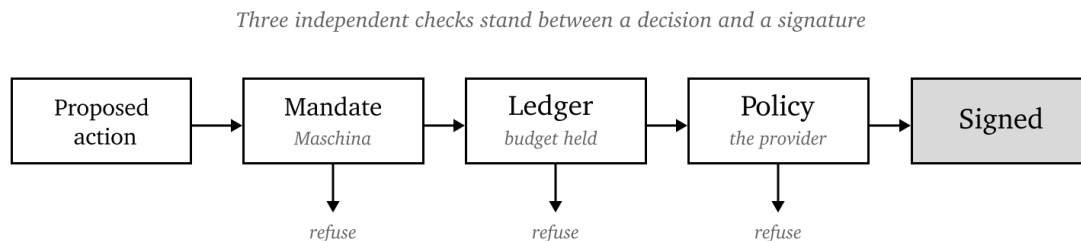
Creation is ordered and verified. The wallet is created, the policy is written onto it, and the policy is read back and compared against what was requested. A mismatch means no machine is created. A funded wallet with nothing holding it is a state this system cannot enter.

3. What the policy permits

Exactly one destination for funds, which is the owner's address. Only assets the owner approved. Only the programs the permitted operations require.

The provider enforces this and knows nothing about Maschina. Compromise every server we operate and this still holds, which is the single most important sentence in this document.

4. The three refusals



Any one refusal is final. The third holds even if Maschina is compromised.

Figure 1. Three independent checks, any one of which refuses alone.

The mandate. Running, in window, approved assets, within per-action, daily and total caps. A limit never set is not permission.

The ledger. Funds reserved under a row lock before signing, settled afterwards against the true cost read back from the chain, proved under concurrent load rather than assumed.

The policy. Enforced by the provider, outside our infrastructure.

5. Separation of powers

Power	Held by	Cannot
Create wallets, write policies	Provisioner credential	Sign anything
Sign transactions	Signer credential	Create wallets or alter policies
Decide what to propose	Nodes	Hold any credential at all

This is why the industry's key compromise figures are relevant to a design document. When roughly forty percent of stolen funds trace to somebody obtaining a key [2], the correct response is not better key hygiene. It is an architecture in which holding the key is insufficient to move the money anywhere the owner did not name.

6. Sent exactly once

An action is sent at most once. Retries reuse the same signature rather than producing a second transaction, so a network failure at the wrong moment cannot result in a duplicate trade.

7. What we assume is already true

1. **Any account can be compromised, including ours.** Nothing about the safety of user funds may depend on our credentials staying secret.
2. **Nodes are hostile.** They hold no keys, and their output is independently checkable.
3. **Machine code is hostile.** It runs isolated, reaching only what it was given.
4. **Providers fail.** Moving a machine's wallet between providers without losing its history is a planned capability rather than an emergency procedure.

8. Controls an owner holds

Pause stops action and keeps everything, reversibly. Stop is terminal by design. A single control halts every machine an owner has. Limits can be tightened at any moment and take effect on the next action.

9. Supply chain and operations

Dependencies pinned. Images pinned by digest. Signed provenance and a bill of materials on every release. Secret scanning and static analysis on every change. No ports open to the internet. Encrypted nightly backups with a restore procedure that has been performed rather than documented.

10. Recovery without us

The procedures by which an owner recovers a machine's funds directly from the key management provider, without Maschina's involvement and without Maschina continuing to exist, is published and kept current.

This matters more than any assurance about our operational practices. A custody claim that depends on the custodian surviving is not a custody claim, it is hope with paperwork.

11. What we do not claim

We do not claim to be unbreakable. Software has defects and ours will too. The guarantee is narrower and considerably more useful: the consequence of a defect is bounded by a machine's own budget, and no defect on our side can redirect funds to a party the owner did not name.

Audit status, and the full report when one exists including whatever it finds, is published in document 14.

12. Reporting a vulnerability

Reports go to the address published at maschina.dev/.well-known/security.txt. Receipt is acknowledged, We do not pursue people who report problems in good faith.

13. References

[2] Chainalysis and industry incident analyses, 2025 and 2026. Approximately 40% of stolen funds trace to private key compromise rather than protocol or contract defects, rising to 43.8% in 2024.